Redes de Computadores e Cibersegurança

Plano de Gerenciamento de Riscos

Motion Tennis

08/11/2026 – 2.0V

Arthur Rodrigues Ferreira – 24026567
Felipe Oluwaseun Santos Ojo – 24026245
Gabriel Henrique Coelho Marussi – 24026609
Nicolas Roberto Jordan Morales – 24025897

SP – 2026

1. Introdução

Aqui reunimos o que vamos fazer em resposta a cada risco de cibersegurança e IoT que identificamos no Motion Tennis, um sistema com sensores acústicos, firmware, processamento, API, tela dedicada e plataforma digital. As ações ainda são propostas: os anexos não provam que já estejam no código ou na arquitetura atual, e por isso o status separa o que está só planejado do que já está em andamento. Indicamos cada responsável pela função e vamos nomear as pessoas na próxima reunião do grupo.

Os dois riscos que entraram agora, privacidade dos dados B2C e rede do estabelecimento parceiro, vêm direto do modelo de negócio da apresentação, com estações em locais parceiros e assinatura para o usuário final.

2. Tabela de Respostas aos Riscos

A tabela liga cada risco priorizado a uma resposta, às ações técnicas, ao responsável por função, ao prazo (contado a partir da aprovação deste plano) e ao status atual.

ID do Risco	Descrição	Nível	Estratégia	Ações Específicas Planejadas	Responsável	Prazo	Status
TEC-SEC-01	21 achados abertos no alvo Tenis-API: 3 críticos, 4 altos, 8 médios e 6 baixos. O PDF não mostra nomes nem linhas, e a amostra cobre só parte do código.	Extremo	Mitigar	1) Exportar os detalhes e confirmar o vínculo do repositório com a versão do Motion Tennis. 2) Triar manualmente os 3 críticos e os 4 altos, registrando causa, arquivo/linha, evidência e reprodutibilidade. 3) Corrigir o que for confirmado, testar regressões e repetir a análise completa.	Líder técnico / API	Triagem D+1; correção antes do próximo release	Não iniciado; ação proposta
TEC-SEC-02	O snapshot do Aikido lista 2 achados SAST altos e 1 baixo em aberto. O PDF não informa tipo nem localização.	Alto	Mitigar	1) Abrir cada alerta detalhado e confirmar manualmente a condição vulnerável. 2) Corrigir os 2 altos e cobrir o comportamento com testes de unidade ou integração. 3) Revisar o baixo e bloquear novos achados críticos ou altos na CI depois de validar a regra.	Responsável pela API / QA	Triagem D+2; altos antes do próximo release	Não iniciado; ação proposta
TEC-SEC-03	O histórico de um repositório tem 16 segredos classificados como baixos. Não há evidência no PDF sobre a validade atual.	Alto	Mitigar	1) Obter a lista de segredos e confirmar escopo, serviço e validade. 2) Revogar e rotacionar na hora qualquer credencial ativa e checar se foi usada. 3) Mover os segredos para um armazenamento apropriado e ativar varredura no commit e na CI. Só reescrever o histórico depois da rotação, combinando com o grupo.	Responsável pelo repositório / API	Validade D+1; rotação imediata se ativo	Em triagem; validade não confirmada
EXT-OSS-01	7 achados médios e 1 baixo em dependências abertas. O monitoramento registra 473 pacotes JavaScript e 6 Python, mas o PDF não lista pacotes nem CVEs.	Alto	Mitigar	1) Exportar pacote, versão e advisory e priorizar pela exposição e pela alcançabilidade no código. 2) Atualizar para as versões corrigidas e manter os lockfiles revisados. 3) Rodar testes da API, de integração e de inicialização e repetir o scan.	Desenvolvimento backend/frontend / QA	Triagem D+3; correção antes do release	Não iniciado; ação proposta

ID do Risco	Descrição	Nível	Estratégia	Ações Específicas Planejadas	Responsável	Prazo	Status
TEC-IAM-01	A auditoria aponta privilégios, acesso à informação e autenticação em monitoramento, sem conformidade completa.	Alto	Mitigar	1) Inventariar endpoints, papéis e dados. 2) Aplicar autorização por recurso e proprietário, privilégio mínimo e MFA para administradores. 3) Testar acesso entre usuários, tokens expirados e ações privilegiadas.	Responsável pela API / segurança	Antes do próximo release	Planejado; não comprovado nos anexos
TEC-NET-01	Segmentação e perímetro não comprovados. O TLS ativo não prova a proteção do enlace sensores-gateway-API.	Alto	Mitigar	1) Separar a rede dos sensores e restringir portas e destinos. 2) Validar TLS e certificados e autenticar as mensagens com identidade por sensor e sequência/nonce. 3) Testar adulteração, replay, queda com reconexão e falha segura.	Responsável por redes / IoT	Antes do teste ponta a ponta	Planejado; não comprovado nos anexos
TEC-IOT-01	Sem evidência de varredura de firmware, de identidade ou de proteção física dos três sensores. Uma adulteração pode falsificar as medições.	Alto	Mitigar	1) Usar credencial única por sensor, remover senhas padrão e desativar depuração desnecessária. 2) Verificar inicialização segura e atualização assinada, registrando versão e calibração. 3) Rejeitar mensagens sem autenticação ou sequência válida e detectar discrepâncias acústicas entre os três sensores.	Responsável por hardware / firmware	Antes da validação física	Planejado; capacidade do hardware a verificar
GER-OPS-01	Backup, logging e retenção de evidências constam como incompletos ou inativos. Um incidente pode passar sem ser detectado ou recuperado.	Alto	Mitigar	1) Centralizar logs com horário, sessão e ID do sensor, sem segredos nem dados desnecessários. 2) Criptografar os backups e testar a restauração. 3) Definir a resposta: isolar, revogar a chave, preservar evidências e avisar o grupo.	Responsável por operação / gerente do projeto	Antes da demonstração final	Planejado; não comprovado nos anexos
GER-COV-01	O Aikido cobre 1 repositório e 1 domínio, a nuvem é N/A e a análise por IA é parcial. A cobertura de firmware, sensores e rede não está confirmada.	Alto	Mitigar	1) Mapear a arquitetura contra repositórios, domínios e ativos monitorados. 2) Incluir API, tela, dependências, IoT/firmware e app móvel. 3) Planejar testes de API, DAST e rede e validar a cobertura a cada release.	Líder de segurança / IoT	Mapeamento D+5; antes do aceite do release	Não iniciado; ação proposta
TEC-PRV-01	Dados dos usuários B2C (cadastro, desempenho e assinatura) podem ser expostos ou coletados além do necessário. A LGPD exige base legal e cuidado extra com iniciantes e possíveis menores.	Alto	Mitigar e transferir (pagamento)	1) Mapear quais dados coletamos, onde ficam e por quanto tempo, e coletar só o necessário. 2) Criptografar em repouso e usar um gateway de pagamento de terceiros, sem guardar dados de cartão. 3) Escrever o aviso de privacidade e o fluxo de exclusão de conta antes do piloto.	Responsável pela plataforma / privacidade	Mapeamento D+5; antes do piloto	Não iniciado; ação proposta
EXT-PAR-01	A rede Wi-Fi do estabelecimento parceiro pode ser compartilhada, instável ou fora do nosso controle, derrubando ou expondo a comunicação dos sensores.	Alto	Mitigar	1) Não depender da rede aberta do parceiro: usar roteador ou gateway próprio, ou VLAN dedicada, sem acesso à rede dos clientes. 2) Prever reconexão automática e guarda local temporária dos eventos. 3) Combinar no termo do piloto quem cuida da rede e quem aciona quem em caso de queda.	Responsável por redes / IoT e gerente do projeto	Antes do piloto	Planejado; depende do local do piloto

ID do Risco	Descrição	Nível	Estratégia	Ações Específicas Planejadas	Responsável	Prazo	Status
TEC-MOB-01	O snapshot lista 3 achados móveis médios. A apresentação confirma que o app faz parte da entrega, mas falta confirmar se o ativo do Aikido é o app do Motion Tennis.	Médio	Mitigar	1) Confirmar a relação do ativo móvel do Aikido com o nosso app. 2) Obter os detalhes, corrigir os 3 alertas e reexecutar a análise. 3) Se não for o nosso app, documentar a justificativa e manter o ativo fora do aceite.	Responsável pelo aplicativo / gerente do projeto	Confirmação D+2; correção antes da entrega	Escopo confirmado; vínculo do ativo a confirmar

3. Detalhamento das Estratégias de Resposta

3.1. Estratégias para Ameaças (Riscos Negativos)

- **Prevenir (Evitar):** mudamos o plano para eliminar a ameaça, o que significa não fazer a atividade que traz o risco.
  - Exemplo: não ativar acesso remoto de administração nas estações do piloto, eliminando essa porta de entrada.
- **Transferir:** passamos o impacto do risco, e a responsabilidade pela resposta, a um terceiro. O risco não some, só muda de mãos.
  - Exemplo: usar um gateway de pagamento para a assinatura B2C em vez de guardar dados de cartão na nossa plataforma.
- **Mitigar:** reduzimos a probabilidade, o impacto ou os dois, até um nível aceitável.
  - Exemplo: testar adulteração e replay na rede dos sensores para diminuir a chance de medições falsas chegarem à tela.
- **Aceitar:** não mudamos o plano por causa do risco.
  - Aceitação ativa: separamos parte dos R$ 300 de contingência e algumas horas para trocar um sensor que falhe.
  - Aceitação passiva: convivemos com um pequeno atraso na tela, sem ação, quando o efeito é baixo.

3.2. Estratégias para Oportunidades (Riscos Positivos)

- **Explorar:** agimos para garantir que a oportunidade aconteça.
  - Exemplo: se a triagem mostrar que muitos achados vêm de poucas dependências, priorizamos essas atualizações para ganhar segurança com pouco esforço.
- **Melhorar (ou Realçar):** aumentamos a chance de a oportunidade acontecer ou o seu ganho.
  - Exemplo: nos preparar melhor nas ferramentas de varredura e em firmware seguro, para tirar mais proveito de cada rodada de testes.
- **Compartilhar:** passamos a oportunidade a quem esteja mais bem posicionado para aproveitá-la a favor do projeto.
  - Exemplo: pedir ao estabelecimento parceiro ou ao professor uma revisão da configuração de rede do piloto.
- **Aceitar:** não vamos atrás da oportunidade, mas aproveitamos se ela surgir.

- Exemplo: se o parceiro oferecer um equipamento de rede melhor sem custo, usamos, mas não contamos com isso.

4. Monitoramento e Revisão

Vamos rever este plano toda semana e depois de qualquer achado crítico ou alto, alteração de arquitetura ou release. Os prazos D+N contam dias corridos a partir da aprovação e precisam ser ajustados ao calendário acadêmico. Atualizamos o status como Não iniciado, Em andamento, Concluído ou Cancelado e guardamos a evidência da correção e o risco residual de cada item.

5. Base de evidências e status de implementação

O O relatório Security Audit Report do Aikido de 08/11/2026, registra 7 dependências médias e 1 baixa, 16 segredos históricos baixos, 2 achados SAST altos e 1 baixo e 3 achados móveis médios.

O export AI Code Analysis do Aikido Security de 08/11/2026, lista 21 achados abertos (3 críticos, 4 altos, 8 médios e 6 baixos) em uma amostra parcial do Motion Tennis.

O relatório também mostra controles ativos de criptografia, TLS, lockfiles e alertas, e lacunas monitoradas em acesso, rede, backups e logging. Contagem zero em uma categoria não quer dizer que a superfície IoT esteja validada. AI Code Analysis e SAST podem se sobrepor, por isso não devemos somar os totais. Os anexos também não trazem nenhuma oportunidade positiva de segurança a explorar. Nenhum dos item aqui está marcado como implementado por enquanto.